

LAPORAN TUGAS AKHIR
IMPLEMENTASI CLOUD SECURITY ARCHITECTURE
PADA SISTEM ADMINISTRASI SEKOLAH MENENGAH KEJURUAN
BERBASIS WEB DENGAN WAF, ZERO TRUST, ENKRIPSI AES-256,
DAN BLOCKCHAIN

Dosen Pengampu: **RUNAL REZKIAWAN, S.Kom., M.T.**



Disusun Oleh:

NAMA : ALAMSYAH SAHLAN

NIM : 105841111823

PROGRAM STUDI TEKNIK INFORMATIKA
FAKULTAS TEKNIK
UNIVERSITAS MUHAMMADIYAH MAKASSAR

2026

KATA PENGANTAR

Puji syukur kehadiran Allah SWT atas segala rahmat dan hidayah-Nya, sehingga penulis dapat menyelesaikan laporan tugas akhir yang berjudul "Implementasi Cloud Security Architecture pada Sistem Administrasi SMK" ini dengan baik dan tepat waktu.

Laporan ini disusun untuk memenuhi tugas final mata kuliah Cloud Security Architecture pada Program Studi Teknik Informatika, Universitas Muhammadiyah Makassar. Penulis mengucapkan terima kasih yang sebesar-besarnya kepada:

1. Allah SWT atas segala rahmat dan kemudahan-Nya.
2. Orang tua dan keluarga yang senantiasa mendoakan dan mendukung.
3. Bapak/Ibu Dosen Pengampu mata kuliah atas bimbingan dan ilmunya.
4. Seluruh rekan mahasiswa yang telah memberikan dukungan.

Penulis menyadari laporan ini masih memiliki kekurangan. Oleh karena itu, kritik dan saran yang membangun sangat diharapkan demi perbaikan di masa mendatang.

Akhir kata, semoga laporan ini dapat memberikan manfaat bagi pembaca, khususnya di bidang keamanan sistem informasi dan teknologi Cloud.

Makassar, Agustus 2026

Alamsyah Sahlan

DAFTAR ISI

KATA PENGANTAR	ii
DAFTAR ISI.....	iii
DAFTAR GAMBAR	v
DAFTAR TABEL	vi
BAB I PENDAHULUAN	1
1.1 Latar Belakang	1
1.2 Rumusan Masalah\.....	2
1.3 Tujuan Penelitian	2
1.4 Manfaat Penelitian	3
1.5 Batasan Masalah.....	3
BAB II LANDASAN TEORI	5
2.1 Cloud Security Architecture.....	5
2.2 Web Application Firewall (WAF)	5
2.3 Zero Trust Architecture.....	6
2.4 Multi-Factor Authentication (MFA)	6
2.5 Role-Based Access Control (RBAC).....	6
2.6 Enkripsi AES-256	7
2.7 Teknologi Blockchain	7
2.8 Smart Contract	7
2.9 Algoritma SHA-256.....	8
2.10 JSON Web Token (JWT).....	8
BAB III METODOLOGI.....	9
3.1 Metode Pengembangan Sistem	9
3.2 Arsitektur Sistem.....	9
3.3 Desain Database	9
3.4 Teknologi yang Digunakan	10
BAB IV HASIL DAN PEMBAHASAN	12
4.1 Implementasi WAF	12
4.2 Implementasi Zero Trust (MFA).....	16
4.3 Implementasi RBAC	17
4.4 Implementasi Enkripsi AES-256	18

4.5 Implementasi Blockchain.....	19
4.6 Portal Verifikasi Publik.....	20
4.7 Audit Log	22
4.8 Pengujian Sistem.....	23
BAB V PENUTUP.....	26
5.1 Kesimpulan	26
5.2 Saran.....	26
DAFTAR PUSTAKA	28

DAFTAR GAMBAR

Gambar 1. Halaman Login Sistem Administrasi SMK.....	13
Gambar 2. Tampilan Dashboard Utama.....	13
Gambar 3. WAF Dashboard - Monitoring Serangan	14
Gambar 4. Simulasi Serangan SQL Injection Diblokir WAF.....	14
Gambar 5. Simulasi Serangan XSS Diblokir WAF	14
Gambar 6. Tabel Log Serangan WAF.....	15
Gambar 7. Halaman MFA Setup.....	15
Gambar 8. QR Code untuk Google Authenticator	16
Gambar 9. Tampilan Login Sebagai Siswa (RBAC)	18
Gambar 10. Perbandingan Menu Admin vs Siswa	18
Gambar 11. Form Tambah Data Siswa	19
Gambar 12. Bagian Data Sensitif (Dienkripsi) AES-256	19
Gambar 13. Halaman Sertifikat & Ijazah Digital.....	20
Gambar 14. Sertifikat dengan Status ISSUED dan Blockchain TX	20
Gambar 15. Portal Verifikasi Publik.....	21
Gambar 16. Hasil Verifikasi Ijazah Valid.....	21
Gambar 17. Tampilan Audit Log	22
Gambar 18. Detail Aktivitas di Audit Log.....	22

DAFTAR TABEL

Tabel 1. Perbandingan Teknologi Keamanan	5
Tabel 2. Struktur Tabel Users	9
Tabel 3. Struktur Tabel Students.....	10
Tabel 4. Teknologi yang Digunakan.....	10
Tabel 5. Pola Serangan yang Dideteksi WAF.....	12
Tabel 6. Daftar Role dan Hak Akses.....	16
Tabel 7. Hasil Pengujian Fungsional	22
Tabel 8. Hasil Pengujian Keamanan	23
Tabel 9. Hasil Pengujian Performa	23

BAB I

PENDAHULUAN

1.1 Latar Belakang

Perkembangan teknologi informasi yang semakin pesat di era digital ini telah membawa perubahan besar dalam berbagai sektor kehidupan, termasuk dunia pendidikan. Sekolah Menengah Kejuruan (SMK) sebagai salah satu institusi pendidikan formal dituntut untuk terus berinovasi dalam pengelolaan data dan sistem administrasinya. Namun, seiring dengan meningkatnya digitalisasi data, ancaman terhadap keamanan sistem informasi juga semakin meningkat secara signifikan.

Berdasarkan laporan Badan Siber dan Sandi Negara (BSSN) tahun 2023, Indonesia mengalami lebih dari 400 juta serangan siber sepanjang tahun tersebut. Sektor pendidikan menjadi salah satu target utama serangan siber karena menyimpan banyak data pribadi sensitif yang berharga, seperti Nomor Induk Kependudukan (NIK), data identitas siswa, data nilai akademik, dan dokumen resmi seperti ijazah. Ancaman-ancaman tersebut meliputi SQL Injection, Cross-Site Scripting (XSS), pencurian kredensial, serangan DDoS, dan pemalsuan dokumen.

Pemalsuan ijazah merupakan salah satu masalah serius yang dihadapi oleh institusi pendidikan maupun dunia kerja di Indonesia. Data dari Kementerian Pendidikan dan Kebudayaan menunjukkan bahwa pemalsuan ijazah masih menjadi praktik yang cukup marak, dengan modus yang semakin canggih seiring berkembangnya teknologi digital. Hal ini merugikan lulusan yang jujur dan merusak kepercayaan publik terhadap lembaga pendidikan.

Menyikapi berbagai tantangan tersebut, konsep Cloud Security Architecture hadir sebagai solusi komprehensif dalam membangun sistem keamanan berlapis. Cloud Security Architecture mengintegrasikan berbagai mekanisme perlindungan seperti Web Application Firewall (WAF), Zero Trust Architecture, enkripsi data, dan teknologi Blockchain untuk menciptakan sistem yang aman, handal, dan terpercaya.

Web Application Firewall (WAF) berperan sebagai garis pertahanan terdepan yang memantau dan menyaring seluruh lalu lintas jaringan secara real-

time. Zero Trust Architecture menerapkan prinsip 'Never Trust, Always Verify' yang mewajibkan verifikasi identitas untuk setiap akses, baik dari dalam maupun luar jaringan. Enkripsi AES-256 memastikan data sensitif tersimpan dalam bentuk yang tidak dapat dibaca oleh pihak yang tidak berwenang. Sementara teknologi Blockchain menjamin integritas dan keaslian dokumen ijazah melalui pencatatan yang permanen dan tidak dapat dimanipulasi.

Berdasarkan latar belakang tersebut, penulis mengembangkan sebuah Sistem Administrasi SMK berbasis web yang mengimplementasikan empat pilar keamanan tersebut secara terintegrasi. Sistem ini dirancang untuk menjawab kebutuhan nyata institusi pendidikan akan platform administrasi yang tidak hanya fungsional, tetapi juga aman dari berbagai ancaman siber modern.

1.2 Rumusan Masalah

Berdasarkan latar belakang yang telah diuraikan, rumusan masalah dalam penelitian ini adalah:

- 1 Bagaimana mengimplementasikan Web Application Firewall (WAF) kustom yang efektif untuk mendeteksi dan memblokir berbagai jenis serangan siber pada sistem administrasi SMK?
- 2 Bagaimana menerapkan Zero Trust Architecture melalui Multi-Factor Authentication (MFA) dan Role-Based Access Control (RBAC) untuk memastikan keamanan akses pengguna?
- 3 Bagaimana mengimplementasikan enkripsi AES-256 untuk melindungi data pribadi sensitif siswa di dalam database?
- 4 Bagaimana mengintegrasikan teknologi Blockchain untuk menjamin integritas dan keaslian dokumen ijazah digital?
- 5 Bagaimana membangun portal verifikasi publik yang memungkinkan pihak eksternal untuk memverifikasi keaslian ijazah secara mudah dan transparan?

1.3 Tujuan Penelitian

Tujuan yang ingin dicapai dalam penelitian ini adalah:

- 1 Mengimplementasikan WAF kustom dengan 5 lapisan perlindungan (Rate Limiting, SQL Injection Filter, XSS Filter, Path Traversal Filter, dan CSRF Protection).

- 2 Menerapkan sistem otentikasi berlapis menggunakan JWT, MFA berbasis TOTP, dan RBAC dengan 6 tingkatan peran pengguna.
- 3 Mengimplementasikan enkripsi AES-256-CBC untuk melindungi data PII (Personally Identifiable Information) siswa.
- 4 Mengintegrasikan Smart Contract Ethereum untuk pencatatan hash ijazah yang permanen dan tidak dapat dimanipulasi.
- 5 Membangun portal verifikasi publik yang dapat digunakan untuk memverifikasi keaslian ijazah tanpa memerlukan akun.

1.4 Manfaat Penelitian

1.4.1 Manfaat Teoritis

- Memberikan kontribusi ilmiah dalam bidang keamanan sistem informasi berbasis web.
- Menjadi referensi implementasi Cloud Security Architecture secara komprehensif.
- Menunjukkan integrasi teknologi Blockchain dalam konteks keamanan dokumen pendidikan.

1.4.2 Manfaat Praktis

- Bagi Institusi: Menyediakan platform administrasi yang aman untuk pengelolaan data siswa dan dokumen resmi.
- Bagi Siswa: Memberikan jaminan keamanan data pribadi dan kemudahan verifikasi ijazah digital.
- Bagi Perusahaan/Instansi: Mempermudah proses verifikasi keaslian ijazah calon karyawan.
- Bagi Pengembang: Menjadi referensi implementasi keamanan berlapis pada aplikasi web modern.

1.5 Batasan Masalah

- 1 Sistem dikembangkan untuk lingkungan Sekolah Menengah Kejuruan (SMK) dengan fokus pada modul administrasi siswa, manajemen nilai, dan sertifikat/ijazah.
- 2 Implementasi Blockchain menggunakan jaringan Ethereum lokal (Hardhat Network) sebagai simulasi, bukan jaringan Ethereum publik.

- 3 Enkripsi AES-256 diterapkan pada data sensitif tertentu (NIK, No. HP, Alamat) dan tidak mencakup seluruh field database.
- 4 Sistem dibangun dan diuji pada lingkungan pengembangan lokal (localhost).
- 5 Sistem menggunakan enam peran pengguna: Administrator, Kepala Sekolah, Tata Usaha, Guru, Siswa, dan DUDI.

BAB II

LANDASAN TEORI

2.1 Cloud Security Architecture

Cloud Security Architecture adalah kerangka desain komprehensif yang mendefinisikan bagaimana kontrol keamanan, kebijakan, dan prosedur diimplementasikan dalam lingkungan cloud computing. Menurut National Institute of Standards and Technology (NIST), Cloud Security Architecture mencakup berbagai aspek keamanan mulai dari perlindungan data, manajemen identitas dan akses, keamanan jaringan, hingga pemantauan dan respons insiden. Prinsip utama Cloud Security Architecture meliputi Defense in Depth (pertahanan berlapis), Zero Trust (tidak mempercayai siapapun secara default), Least Privilege (hak akses minimal), dan Separation of Duties (pemisahan tanggung jawab). Keempat prinsip ini bekerja secara sinergis untuk menciptakan sistem yang tahan terhadap berbagai vektor serangan.

2.2 Web Application Firewall (WAF)

Web Application Firewall (WAF) adalah solusi keamanan yang beroperasi pada lapisan aplikasi (Layer 7) dari model OSI untuk memantau, menyaring, dan memblokir lalu lintas HTTP/HTTPS yang berpotensi berbahaya. Berbeda dengan firewall tradisional yang bekerja pada lapisan jaringan, WAF memiliki kemampuan untuk menganalisis konten request dan respons secara mendalam.

WAF umumnya melindungi aplikasi web dari serangan-serangan yang tercantum dalam OWASP Top 10, termasuk: SQL Injection, Cross-Site Scripting (XSS), Broken Authentication, Sensitive Data Exposure, XML External Entities (XXE), Broken Access Control, Security Misconfiguration, Insecure Deserialization, Using Components with Known Vulnerabilities, dan Insufficient Logging and Monitoring.

Tabel 1. Perbandingan Teknologi Keamanan Web

Teknologi	Fungsi Utama	Layer Perlindungan
WAF	Memblokir serangan web (SQLi, XSS)	Layer 7 (Aplikasi)
Firewall Jaringan	Memfilter lalu lintas berdasarkan IP/Port	Layer 3-4 (Jaringan)

IDS/IPS	Mendeteksi dan mencegah intrusi	Layer 3-7
DLP	Mencegah kebocoran data	Layer 7

2.3 Zero Trust Architecture

Zero Trust Architecture (ZTA) adalah model keamanan yang diperkenalkan oleh John Kindervag dari Forrester Research pada tahun 2010. Filosofi dasar Zero Trust adalah 'Never Trust, Always Verify' — artinya tidak ada pengguna, perangkat, atau jaringan yang secara otomatis dipercaya, baik yang berasal dari dalam maupun luar perimeter jaringan organisasi.

Zero Trust Architecture dibangun di atas tiga pilar utama: Verifikasi Identitas Secara Eksplisit (selalu otentikasi dan otorisasi berdasarkan semua data yang tersedia), Gunakan Akses Hak Minimum (batasi akses pengguna dengan Just-In-Time dan Just-Enough-Access), dan Asumsikan Pelanggaran (minimalkan jangkauan serangan, segmentasikan akses, dan enkripsi seluruh data).

2.4 Multi-Factor Authentication (MFA)

Multi-Factor Authentication (MFA) adalah mekanisme keamanan yang mengharuskan pengguna membuktikan identitasnya melalui dua atau lebih faktor autentikasi yang independen. Faktor-faktor tersebut dikategorikan menjadi: Something you know (sesuatu yang Anda ketahui, misalnya password), Something you have (sesuatu yang Anda miliki, misalnya smartphone), dan Something you are (sesuatu yang menjadi bagian dari diri Anda, misalnya sidik jari).

Sistem ini mengimplementasikan MFA berbasis TOTP (Time-based One-Time Password) sesuai standar RFC 6238. TOTP menghasilkan kode satu kali pakai yang berubah setiap 30 detik berdasarkan kombinasi antara kunci rahasia pengguna dan timestamp Unix saat ini. Implementasi ini kompatibel dengan aplikasi Google Authenticator, Authy, dan Microsoft Authenticator.

2.5 Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) adalah model kontrol akses di mana hak akses diberikan kepada peran (role) tertentu, bukan langsung kepada individu

pengguna. Pengguna kemudian diberikan satu atau lebih peran, dan melalui peran tersebut mereka mendapatkan hak akses yang sesuai. RBAC menerapkan prinsip Least Privilege, yaitu setiap pengguna hanya diberikan hak akses minimum yang diperlukan untuk menjalankan tugasnya.

2.6 Enkripsi AES-256

Advanced Encryption Standard (AES) adalah standar enkripsi simetrik yang ditetapkan oleh National Institute of Standards and Technology (NIST) Amerika Serikat pada tahun 2001. AES-256 menggunakan kunci enkripsi sepanjang 256-bit, yang berarti terdapat 2^{256} kemungkinan kombinasi kunci, menjadikannya sangat resisten terhadap serangan brute force.

Mode CBC (Cipher Block Chaining) yang digunakan dalam implementasi ini memastikan bahwa setiap blok ciphertext bergantung pada semua blok plaintext sebelumnya melalui operasi XOR, sehingga pola yang sama dalam plaintext tidak akan menghasilkan pola yang sama dalam ciphertext. Initialization Vector (IV) yang acak digunakan untuk setiap operasi enkripsi guna mencegah serangan replay attack.

2.7 Teknologi Blockchain

Blockchain adalah struktur data terdistribusi yang terdiri dari serangkaian blok yang saling terhubung secara kriptografis. Setiap blok berisi: hash dari blok sebelumnya (membentuk rantai), data transaksi, timestamp, dan nonce (bilangan yang digunakan dalam proses mining). Karakteristik utama Blockchain adalah immutability (data yang sudah tercatat tidak dapat diubah), transparency (dapat diverifikasi oleh semua pihak), dan decentralization (tidak dikontrol oleh satu entitas tunggal).

2.8 Smart Contract

Smart Contract adalah program komputer yang berjalan di atas jaringan Blockchain dan mengeksekusi perjanjian secara otomatis ketika kondisi yang telah ditentukan terpenuhi. Smart Contract ditulis dalam bahasa pemrograman Solidity untuk platform Ethereum. Setelah di-deploy ke jaringan Blockchain, kode Smart Contract bersifat immutable dan dapat diverifikasi secara publik.

Dalam sistem ini, Smart Contract CertificateRegistry digunakan untuk menyimpan hash dokumen ijazah secara permanen. Setiap fungsi dalam Smart

Contract mencatat event yang dapat dipantau secara real-time. Smart Contract dikembangkan menggunakan framework Hardhat dan diuji pada jaringan Ethereum lokal.

2.9 Algoritma SHA-256

SHA-256 (Secure Hash Algorithm 256-bit) adalah fungsi hash kriptografis yang menghasilkan digest berukuran tetap 256-bit (32 byte) dari data masukan dengan ukuran berapa pun. SHA-256 merupakan bagian dari keluarga SHA-2 yang dikembangkan oleh National Security Agency (NSA) Amerika Serikat. Sifat-sifat penting SHA-256 adalah: Deterministic (input yang sama selalu menghasilkan output yang sama), One-way (tidak dapat dikembalikan ke input asli), Collision-resistant (sangat sulit menemukan dua input berbeda yang menghasilkan output sama), dan Avalanche effect (perubahan kecil pada input menghasilkan perubahan besar pada output).

2.10 JSON Web Token (JWT)

JSON Web Token (JWT) adalah standar terbuka (RFC 7519) yang mendefinisikan cara yang kompak dan mandiri untuk mentransmisikan informasi antar pihak sebagai objek JSON. JWT terdiri dari tiga bagian yang dipisahkan oleh titik: Header (berisi algoritma dan tipe token), Payload (berisi klaim/data pengguna), dan Signature (tanda tangan digital untuk memverifikasi keaslian).

BAB III

METODOLOGI

3.1 Metode Pengembangan Sistem

Pengembangan sistem ini menggunakan metode Waterfall yang dimodifikasi dengan pendekatan iteratif. Metode Waterfall dipilih karena kebutuhan sistem sudah terdefinisi dengan jelas sejak awal, memungkinkan perencanaan yang terstruktur dan komprehensif. Tahapan pengembangan meliputi: Analisis Kebutuhan, Desain Sistem, Implementasi, Pengujian, dan Deployment.

3.2 Arsitektur Sistem

Sistem dibangun menggunakan arsitektur three-tier yang terdiri dari:

- 1 Presentation Layer (Frontend): Dibangun menggunakan React.js dengan Vite sebagai build tool. Tailwind CSS digunakan untuk styling, dan Recharts untuk visualisasi data pada WAF Dashboard.
- 2 Business Logic Layer (Backend): Dibangun menggunakan Node.js dengan framework Express.js. Layer ini menangani autentikasi JWT, WAF middleware, enkripsi data, dan komunikasi dengan Blockchain.
- 3 Data Layer: Menggunakan SQLite sebagai database utama melalui library SQL.js (versi WebAssembly). Blockchain layer menggunakan Hardhat Network dengan Smart Contract Solidity.

3.3 Desain Database

Sistem menggunakan enam tabel utama dalam database SQLite:

Tabel 2. Struktur Tabel Users

Field	Tipe Data	Keterangan
id	TEXT (UUID)	Primary Key
username	TEXT	Nama pengguna (UNIQUE)
password	TEXT	Hash bcrypt
full_name	TEXT	Nama lengkap
role	TEXT	ADMIN/KEPALA_SEKOLAH/TU/GURU/SISWA/DUDI

mfa_secret	TEXT	Secret key TOTP
mfa_enabled	INTEGER	Status MFA (0/1)

Tabel 3. Struktur Tabel Students

Field	Type Data	Keterangan
id	TEXT (UUID)	Primary Key
nis	TEXT	Nomor Induk Siswa (UNIQUE)
full_name	TEXT	Nama lengkap siswa
class	TEXT	Kelas
major	TEXT	Jurusan
encrypted_nik	TEXT	NIK terenkripsi AES-256
encrypted_phone	TEXT	No HP terenkripsi
encrypted_address	TEXT	Alamat terenkripsi

3.4 Teknologi yang Digunakan

Tabel 4. Teknologi yang Digunakan

Teknologi	Versi	Fungsi
Node.js	v24.18.0	Runtime JavaScript backend
Express.js	v4.18.2	Framework web backend
React.js	v18.2.0	Library frontend UI
Vite	v5.4.21	Build tool dan dev server frontend
SQL.js	v1.11.0	Database SQLite berbasis WebAssembly
Ethers.js	v6.9.0	Library interaksi Ethereum Blockchain
Hardhat	v2.19.0	Framework pengembangan Smart

		Contract
Solidity	v0.8.19	Bahasa pemrograman Smart Contract
Speakeasy	v2.0.0	Library TOTP untuk MFA
bcryptjs	v2.4.3	Library hashing password
jsonwebtoken	v9.0.2	Library JWT autentikasi
Tailwind CSS	v3.4.0	Framework CSS utility- first

BAB IV

HASIL DAN PEMBAHASAN

4.1 Implementasi Web Application Firewall (WAF)

WAF diimplementasikan sebagai middleware Express.js dengan 5 lapisan perlindungan yang bekerja secara berurutan sebelum setiap request mencapai logika aplikasi. Pendekatan berlapis ini memastikan bahwa request yang lolos dari satu lapisan masih dapat tertangkap oleh lapisan berikutnya.

4.1.1 Layer 1: Rate Limiting

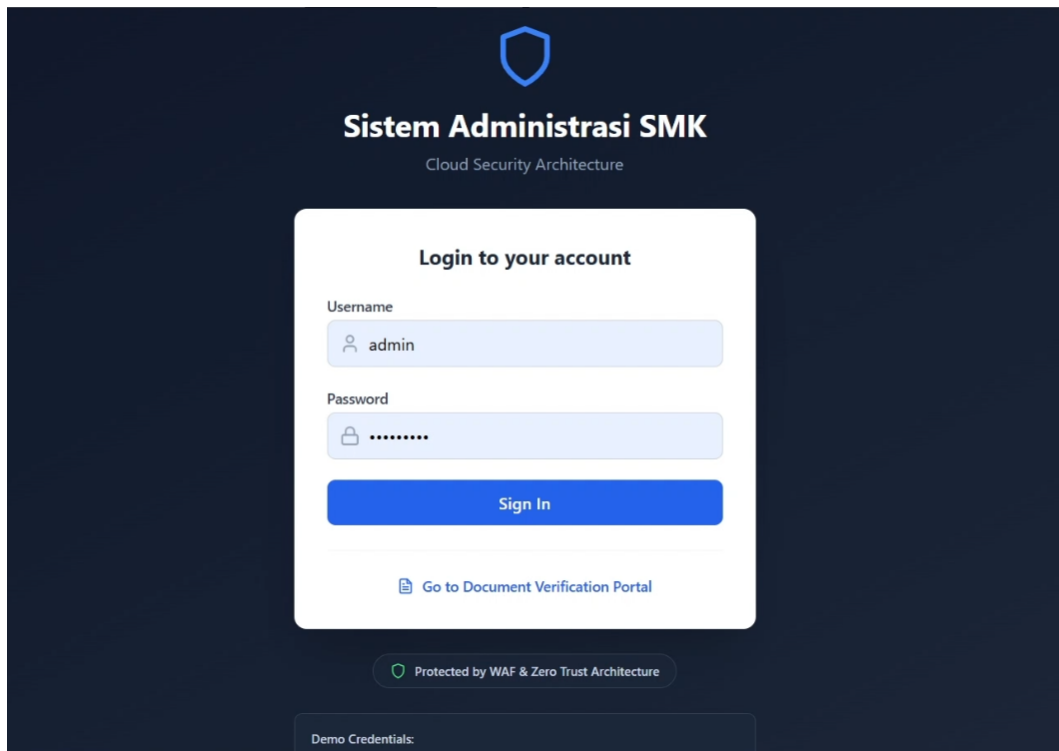
Rate Limiting diimplementasikan menggunakan library express-rate-limit. Konfigurasi umum membatasi 100 request per 15 menit per IP address, sementara endpoint login dibatasi lebih ketat dengan 50 percobaan per 15 menit. Ketika batas terlampaui, server merespons dengan status HTTP 429 (Too Many Requests) dan mencatat kejadian ke dalam WAF logs.

4.1.2 Layer 2: SQL Injection dan XSS Filter

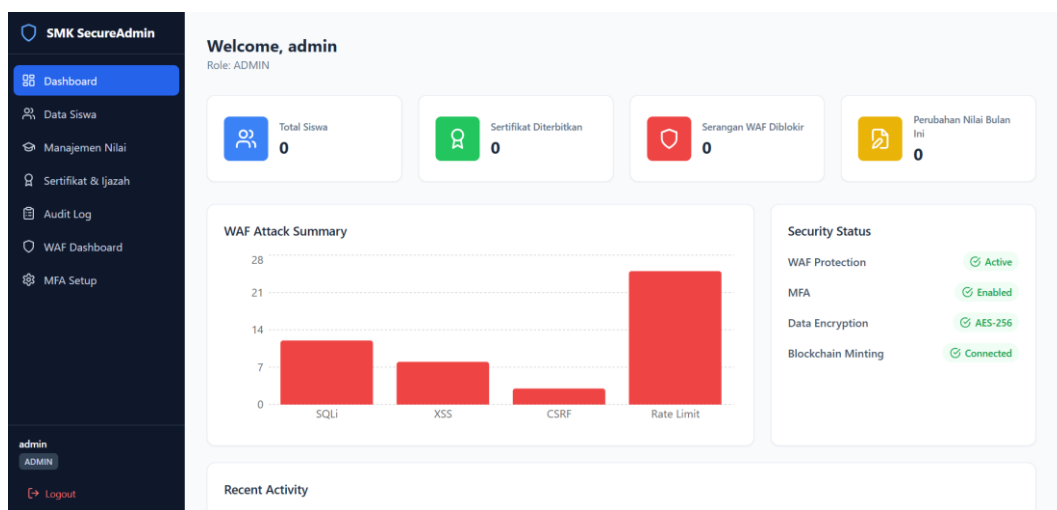
Filter ini menggunakan teknik Regular Expression (Regex) Pattern Matching untuk memindai seluruh komponen request secara rekursif, meliputi request body, query parameters, URL parameters, dan HTTP headers. Pola SQL Injection yang dideteksi meliputi: UNION SELECT, OR 1=1, DROP TABLE, INSERT INTO, DELETE FROM, UPDATE SET, comment sequences (--, /*), dan fungsi berbahaya seperti xp_cmdshell dan exec(). Pola XSS yang dideteksi meliputi: tag <script>, javascript: URI, event handler (onerror=, onload=), fungsi eval(), dan akses document.cookie.

Tabel 5. Pola Serangan yang Dideteksi WAF

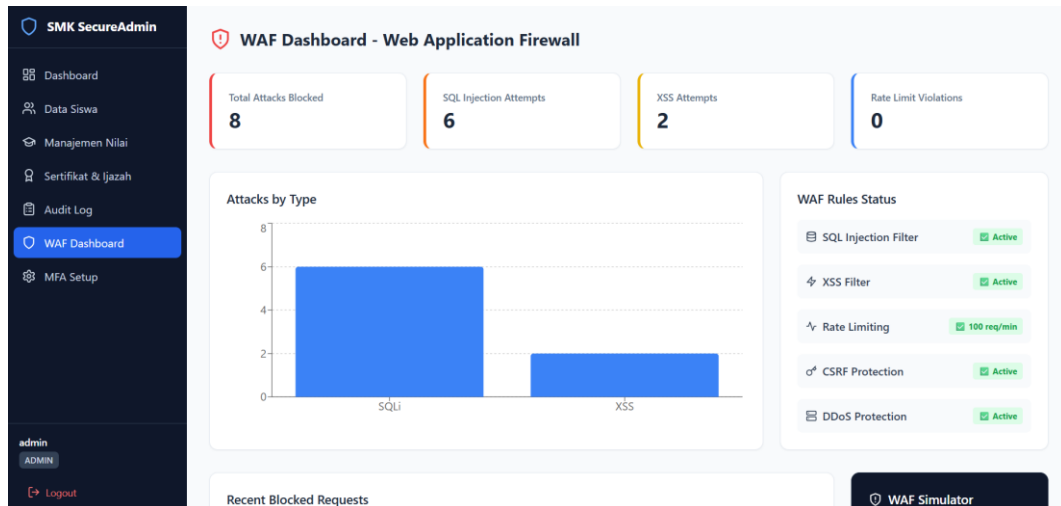
Jenis Serangan	Contoh Payload	Severity
SQL Injection	' OR '1'='1' --	CRITICAL
SQL Injection	'; DROP TABLE users; --	CRITICAL
XSS	<script>alert('XSS')</script>	HIGH
XSS	onerror=alert(document.cookie)	HIGH
Path Traversal	../../../../etc/passwd	CRITICAL
Rate Limit	> 50 login attempts/15min	MEDIUM



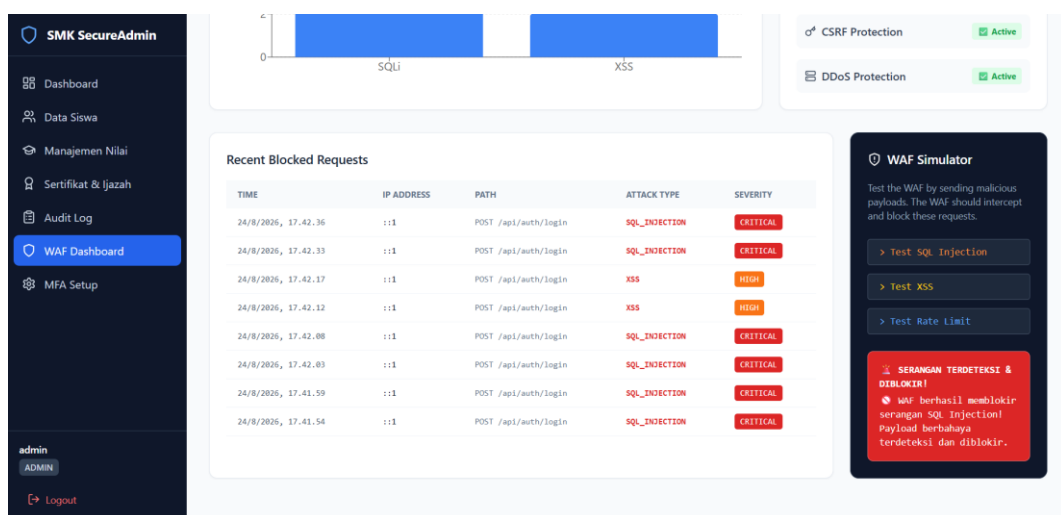
Gambar 1. Halaman Login Sistem Administrasi SMK



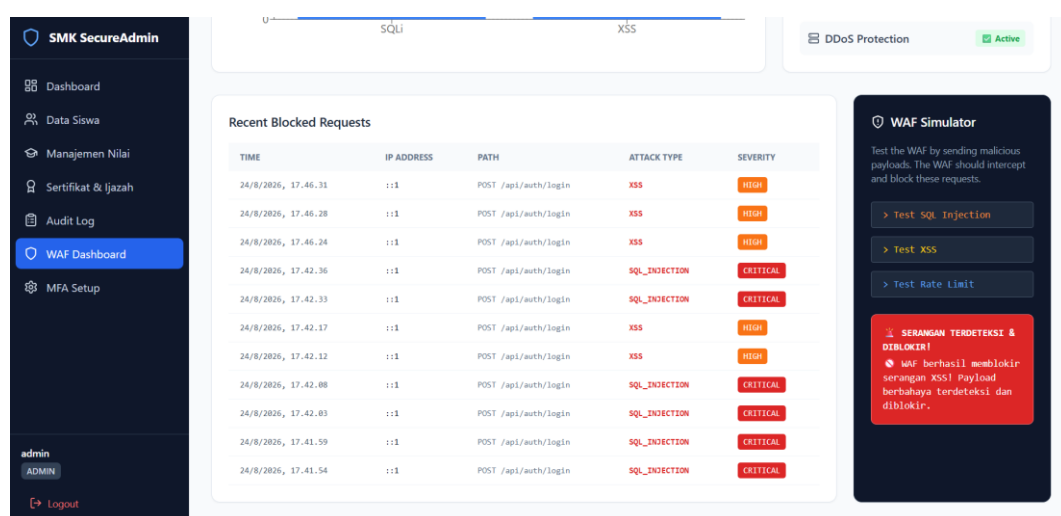
Gambar 2. Tampilan Dashboard Utama



Gambar 3. WAF Dashboard - Monitoring Serangan Real-time



Gambar 4. Simulasi Serangan SQL Injection Diblokir WAF



Gambar 5. Simulasi Serangan XSS Diblokir WAF

Recent Blocked Requests

TIME	IP ADDRESS	PATH	ATTACK TYPE	SEVERITY
24/8/2026, 17.46.31	::1	POST /api/auth/login	XSS	HIGH
24/8/2026, 17.46.28	::1	POST /api/auth/login	XSS	HIGH
24/8/2026, 17.46.24	::1	POST /api/auth/login	XSS	HIGH
24/8/2026, 17.42.36	::1	POST /api/auth/login	SQL_INJECTION	CRITICAL
24/8/2026, 17.42.33	::1	POST /api/auth/login	SQL_INJECTION	CRITICAL
24/8/2026, 17.42.17	::1	POST /api/auth/login	XSS	HIGH
24/8/2026, 17.42.12	::1	POST /api/auth/login	XSS	HIGH
24/8/2026, 17.42.08	::1	POST /api/auth/login	SQL_INJECTION	CRITICAL
24/8/2026, 17.42.03	::1	POST /api/auth/login	SQL_INJECTION	CRITICAL
24/8/2026, 17.41.59	::1	POST /api/auth/login	SQL_INJECTION	CRITICAL
24/8/2026, 17.41.54	::1	POST /api/auth/login	SQL_INJECTION	CRITICAL

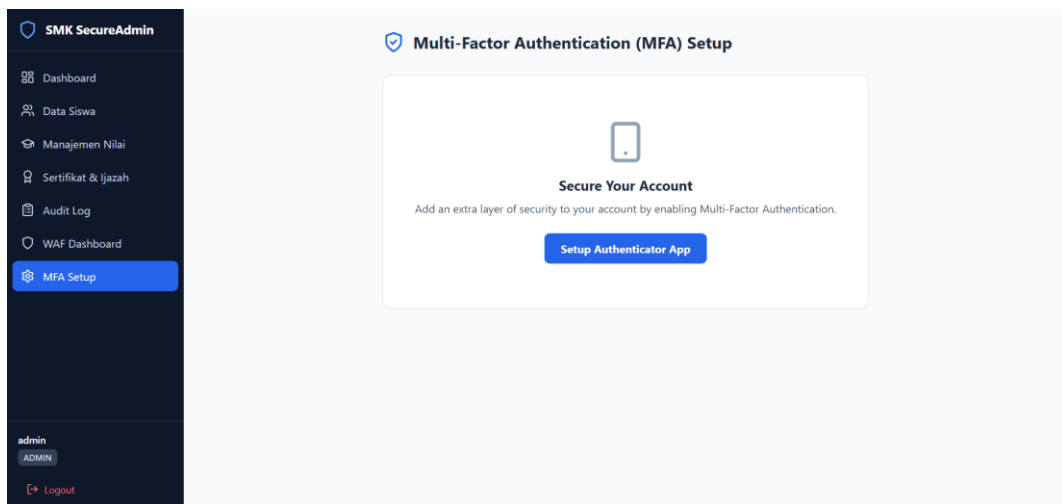
Gambar 6. Tabel Log Serangan WAF dengan Detail IP dan Timestamp

Gambar 3 menunjukkan tampilan WAF Dashboard yang menampilkan statistik serangan secara real-time, meliputi total serangan yang diblokir, distribusi jenis serangan dalam bentuk grafik batang, dan tabel riwayat serangan. Gambar 4 dan 5 menunjukkan respons sistem saat mendeteksi serangan SQL Injection dan XSS, dengan tampilan peringatan merah yang jelas menandakan serangan telah diblokir.

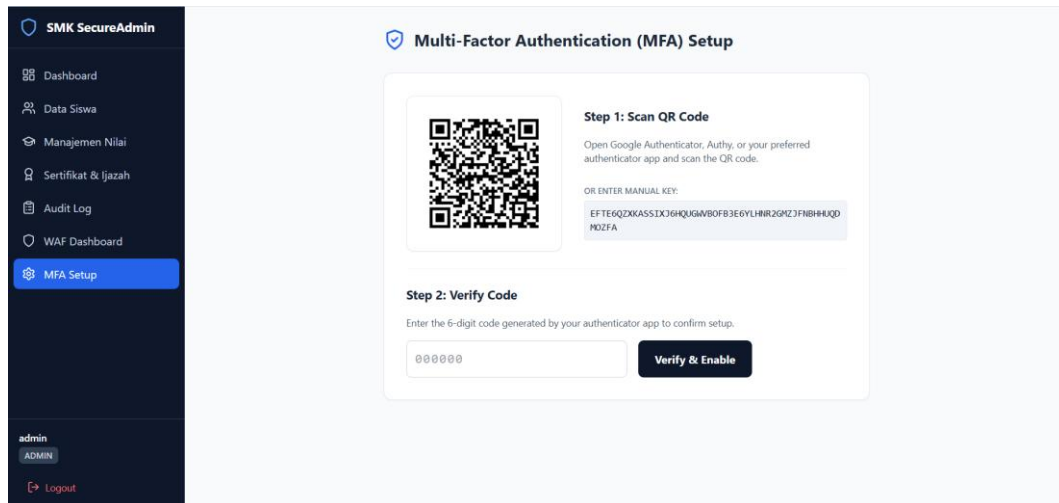
4.2 Implementasi Zero Trust — Multi-Factor Authentication

MFA diimplementasikan menggunakan protokol TOTP (Time-based One-Time Password) sesuai standar RFC 6238 melalui library Speakeasy. Proses setup MFA terdiri dari tiga tahap:

- 1 Server menghasilkan secret key menggunakan Speakeasy dan menyimpannya di database yang terenkripsi,
- 2 Server menghasilkan QR Code dalam format data URL menggunakan library qrcode yang berisi otpauth URI dengan format 'otpauth://totp/AppName:username?secret=BASE32SECRET', dan
- 3 Pengguna men-scan QR Code menggunakan aplikasi Google Authenticator di smartphone, kemudian memasukkan kode 6 digit untuk verifikasi dan aktivasi.



Gambar 7. Halaman MFA Setup dengan Tombol Setup Authenticator



Gambar 8. QR Code / Barcode untuk Scan Google Authenticator

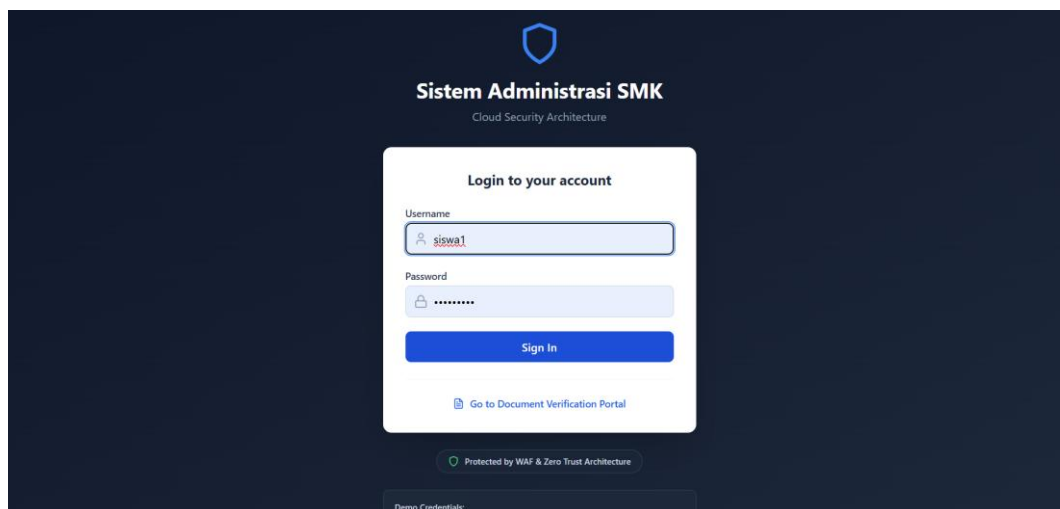
Gambar 7 menunjukkan halaman MFA Setup yang memandu pengguna melalui dua langkah: scan QR Code dan verifikasi kode. Gambar 8 menampilkan QR Code yang dihasilkan secara dinamis oleh sistem, yang berisi informasi akun yang dikodekan dan dapat di-scan oleh aplikasi Google Authenticator, Authy, atau aplikasi TOTP lainnya.

4.3 Implementasi Role-Based Access Control (RBAC)

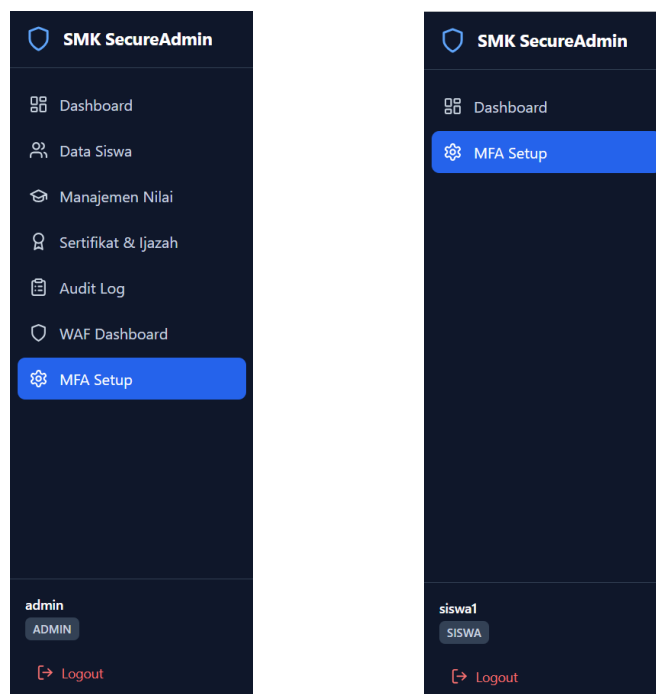
RBAC diimplementasikan pada dua level sekaligus untuk memastikan keamanan yang komprehensif. Pada level Backend, middleware authorize() memeriksa role pengguna sebelum setiap request diproses. Jika role tidak memenuhi persyaratan, server mengembalikan status HTTP 403 (Forbidden). Pada level Frontend, komponen React secara kondisional merender menu dan fitur berdasarkan role pengguna yang tersimpan dalam JWT payload.

Tabel 6. Daftar Role dan Hak Akses Sistem

Role	Data Siswa	Sertifikat	WAF/Audit
ADMIN	Full Access	Terbitkan & Lihat	Full Access
KEPALA_SEKOLAH	Lihat	Approve & Lihat	Lihat
GURU	Lihat	Tidak bisa	Tidak bisa
TU	Full Access	Terbitkan	Tidak bisa
SISWA	Data sendiri	Tidak bisa	Tidak bisa
DUDI	Tidak bisa	Verifikasi	Tidak bisa



Gambar 9. Tampilan Login Sebagai Siswa - Menu Terbatas (RBAC)



Gambar 10. Perbandingan Menu: Admin (Lengkap) vs Siswa (Terbatas)

4.4 Implementasi Enkripsi AES-256

Enkripsi AES-256-CBC diimplementasikan pada tiga field yang dikategorikan sebagai PII (Personally Identifiable Information): NIK (Nomor Induk Kependudukan), Nomor HP, dan Alamat Lengkap. Kunci enkripsi (256-bit) dan Initialization Vector (128-bit) disimpan secara aman di file environment (.env) yang tidak pernah di-commit ke repository.

Proses enkripsi dilakukan sebelum data disimpan ke database, dan proses dekripsi dilakukan hanya ketika data diakses oleh pengguna yang terautentikasi

dan memiliki hak akses yang sesuai. Data yang tersimpan di database berbentuk string hexadecimal yang tidak dapat dibaca tanpa kunci enkripsi yang benar.



Tambah Siswa Baru ✕

NIS

NISN

Nama Lengkap

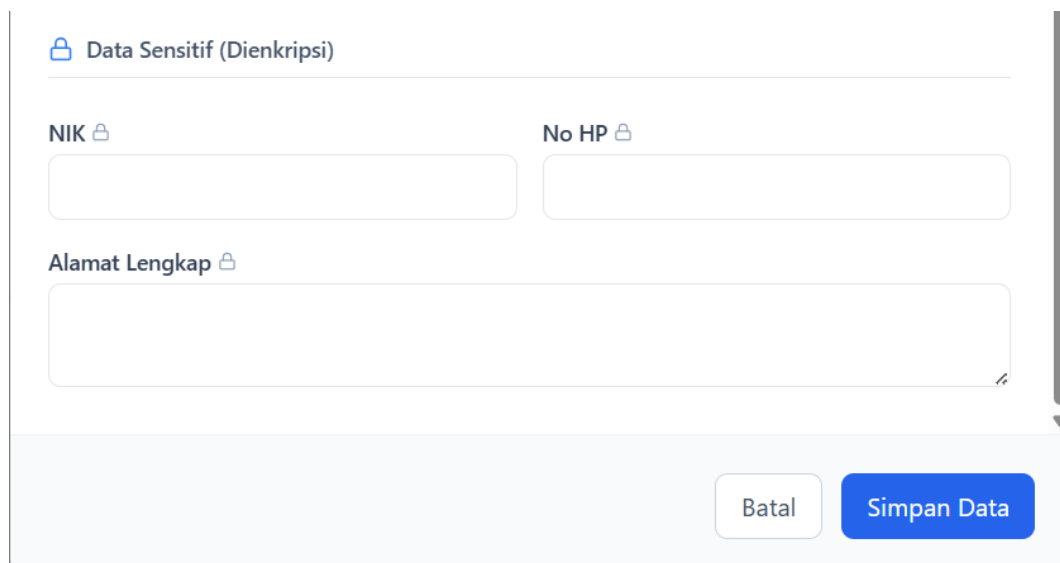
Tempat Lahir

Tanggal Lahir 

Kelas

Jurusan

Gambar 11. Form Tambah Data Siswa dengan Semua Field



 Data Sensitif (Dienkripsi)

NIK 

No HP 

Alamat Lengkap 

Gambar 12. Bagian 'Data Sensitif (Dienkripsi)' dengan Ikon Gembok AES-

256

4.5 Implementasi Blockchain

Teknologi Blockchain diimplementasikan menggunakan jaringan Ethereum lokal yang dikelola oleh framework Hardhat. Smart Contract

CertificateRegistry ditulis dalam bahasa Solidity dan di-deploy ke jaringan Hardhat Network yang berjalan di localhost:8545.

Alur proses penerbitan ijazah dengan Blockchain adalah sebagai berikut: (1) Staf TU atau Admin mengupload file PDF ijazah dan memilih siswa yang bersangkutan, (2) Sistem menghitung hash SHA-256 dari file PDF tersebut, (3) Data ijazah dengan status PENDING disimpan ke database SQLite, (4) Kepala Sekolah melakukan persetujuan (approve) melalui sistem, (5) Sistem memanggil fungsi `issueCertificate()` pada Smart Contract dengan parameter `studentId`, `certType`, dan `pdfHash`, (6) Ethereum Blockchain memproses transaksi dan mengembalikan Transaction Hash, (7) Status ijazah diperbarui menjadi ISSUED dengan Transaction Hash yang diterima.

NO. SERTIFIKAT	NAMA SISWA	TIPE	STATUS	BLOCKCHAIN TX	AKSI
UJZ-2026-00724	Alamsyah Sahlan	IJAZAH	ISSUED	0xc7b2948e4ea2b...	
UJZ-2026-00585	Budi Darmawan	IJAZAH	PENDING	-	

Gambar 13. Halaman Sertifikat & Ijazah Digital - Daftar Semua Ijazah

NO. SERTIFIKAT	NAMA SISWA	TIPE	STATUS	BLOCKCHAIN TX	AKSI
UJZ-2026-00724	Alamsyah Sahlan	IJAZAH	ISSUED	0xc7b2948e4ea2b...	
UJZ-2026-00585	Budi Darmawan	IJAZAH	ISSUED	0xe13816ccae19a...	

Gambar 14. Detail Ijazah dengan Status ISSUED dan Kode Blockchain TX

4.6 Portal Verifikasi Publik

Portal Verifikasi Publik dapat diakses di path /verify tanpa memerlukan autentikasi. Portal ini dirancang untuk digunakan oleh pihak eksternal seperti perusahaan, instansi pemerintah, atau universitas yang ingin memverifikasi keaslian ijazah lulusan.

Proses verifikasi bekerja sebagai berikut: (1) Pengguna mengupload file PDF ijazah yang ingin diverifikasi, (2) Browser menghitung hash SHA-256 dari file tersebut menggunakan Web Crypto API secara lokal, (3) Hash dikirimkan ke backend API, (4) Backend mencocokkan hash dengan data di database dan Blockchain, (5) Hasil verifikasi ditampilkan beserta detail ijazah jika ditemukan.

The screenshot shows the 'Portal Verifikasi Dokumen SMK' interface. At the top, there is a blue shield icon and the title 'Portal Verifikasi Dokumen SMK'. Below the title, a subtitle reads: 'Verifikasi keaslian ijazah, transkrip, dan sertifikat menggunakan teknologi Blockchain.' The main form area contains a dashed box with an upload icon and the text 'Pilih File PDF atau Drag & Drop ke sini' and 'Maksimal ukuran file: 5MB'. Below this, there is a link 'Atau masukkan hash manual' and a text input field labeled 'Masukkan SHA-256 Hash dokumen'. A blue button labeled 'Verifikasi Dokumen' is at the bottom of the form. At the very bottom of the page, small text reads 'Desain dan Blockchain Technology By Yoon, Teet, Aschitektur'.

Gambar 15. Portal Verifikasi Publik - Form Upload PDF

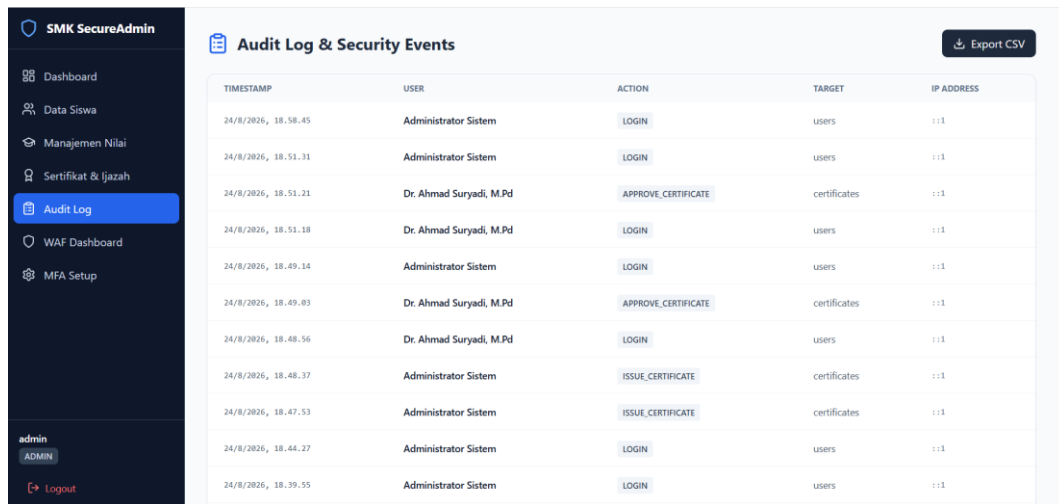
The screenshot shows the successful verification result. At the top, the filename 'Laporan_Tugas_Final_CTI_Alamsyah_Sahlan_10584111823 (1).pdf' is displayed with the note 'Maksimal ukuran file: 5MB'. Below this is the 'Atau masukkan hash manual' link and the 'Masukkan SHA-256 Hash dokumen' input field. A blue 'Verifikasi Dokumen' button is present. The result is shown in a green box with a checkmark icon and the title 'Dokumen Valid (Terverifikasi)'. Below the title, it says 'Tercatat dalam blockchain dan tidak mengalami perubahan.' A table displays the document details:

Nama:	Alamsyah Sahlan
Tipe:	IJAZAH
Penerbit:	SMK Negeri (Blockchain Verified)
Tx Hash:	0x7bb2948e4ea2b8abc883bae04bac64591315b56c85217b95ff10a0fca9ffbe

Gambar 16. Hasil Verifikasi: Ijazah Valid (Terverifikasi Blockchain)

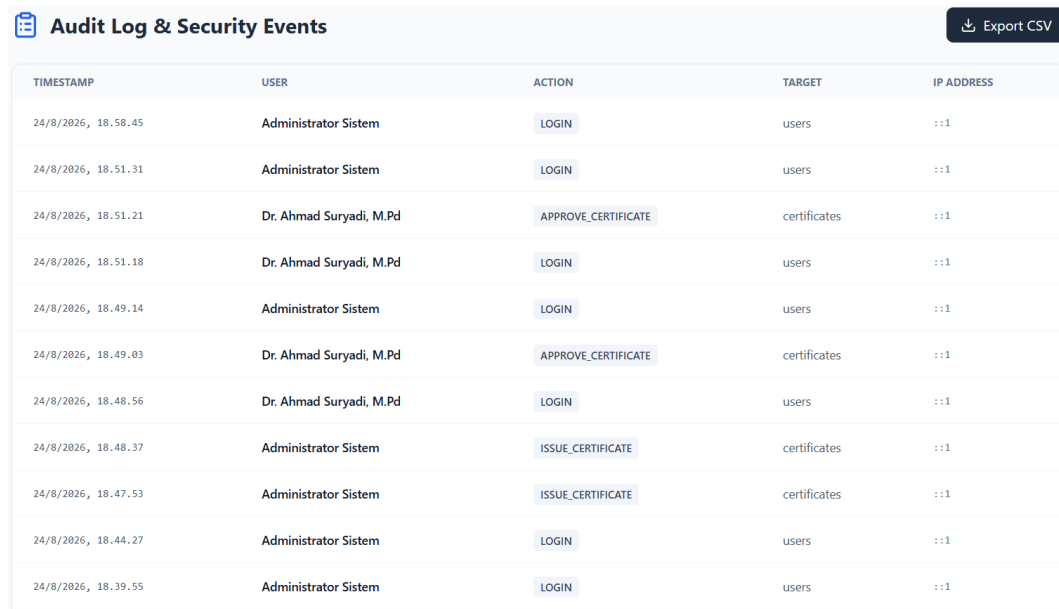
4.7 Audit Log

Audit Trail diimplementasikan untuk mencatat seluruh aktivitas penting dalam sistem. Setiap aksi yang dicatat meliputi: informasi pengguna yang melakukan aksi (user_id), jenis aksi (LOGIN, CREATE_STUDENT, ISSUE_CERTIFICATE, dll.), tabel yang terpengaruh, ID record yang dimodifikasi, nilai sebelum dan sesudah perubahan (old_value, new_value), IP Address pengguna, dan timestamp kejadian.



TIMESTAMP	USER	ACTION	TARGET	IP ADDRESS
24/8/2026, 18.58.45	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.51.31	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.51.21	Dr. Ahmad Suryadi, M.Pd	APPROVE_CERTIFICATE	certificates	::1
24/8/2026, 18.51.18	Dr. Ahmad Suryadi, M.Pd	LOGIN	users	::1
24/8/2026, 18.49.14	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.49.03	Dr. Ahmad Suryadi, M.Pd	APPROVE_CERTIFICATE	certificates	::1
24/8/2026, 18.48.56	Dr. Ahmad Suryadi, M.Pd	LOGIN	users	::1
24/8/2026, 18.48.37	Administrator Sistem	ISSUE_CERTIFICATE	certificates	::1
24/8/2026, 18.47.53	Administrator Sistem	ISSUE_CERTIFICATE	certificates	::1
24/8/2026, 18.44.27	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.39.55	Administrator Sistem	LOGIN	users	::1

Gambar 17. Tampilan Halaman Audit Log



TIMESTAMP	USER	ACTION	TARGET	IP ADDRESS
24/8/2026, 18.58.45	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.51.31	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.51.21	Dr. Ahmad Suryadi, M.Pd	APPROVE_CERTIFICATE	certificates	::1
24/8/2026, 18.51.18	Dr. Ahmad Suryadi, M.Pd	LOGIN	users	::1
24/8/2026, 18.49.14	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.49.03	Dr. Ahmad Suryadi, M.Pd	APPROVE_CERTIFICATE	certificates	::1
24/8/2026, 18.48.56	Dr. Ahmad Suryadi, M.Pd	LOGIN	users	::1
24/8/2026, 18.48.37	Administrator Sistem	ISSUE_CERTIFICATE	certificates	::1
24/8/2026, 18.47.53	Administrator Sistem	ISSUE_CERTIFICATE	certificates	::1
24/8/2026, 18.44.27	Administrator Sistem	LOGIN	users	::1
24/8/2026, 18.39.55	Administrator Sistem	LOGIN	users	::1

Gambar 18. Detail Entri Audit Log dengan Informasi Lengkap

4.8 Pengujian Sistem

4.8.1 Pengujian Fungsional

Tabel 7. Hasil Pengujian Fungsional

No	Skenario Pengujian	Hasil yang Diharapkan	Status
1	Login dengan kredensial valid	Berhasil login, token JWT diterima	✓ Berhasil
2	Login dengan kredensial tidak valid	Pesan error 'Invalid credentials'	✓ Berhasil
3	Tambah data siswa baru	Data tersimpan dengan enkripsi AES-256	✓ Berhasil
4	Setup MFA dan scan QR Code	QR Code muncul, MFA dapat diaktifkan	✓ Berhasil
5	Akses menu terlarang sebagai Siswa	HTTP 403 Forbidden dikembalikan	✓ Berhasil
6	Upload dan terbitkan ijazah	PDF diproses, hash SHA-256 dihitung	✓ Berhasil
7	Approve ijazah oleh Kepala Sekolah	Status ISSUED, TX Hash Blockchain tersimpan	✓ Berhasil
8	Verifikasi ijazah asli di portal publik	Hasil: Valid dan Terverifikasi	✓ Berhasil
9	Verifikasi ijazah palsu (file diedit)	Hasil: Tidak Ditemukan /	✓ Berhasil

		Tidak Valid	
10	Lihat Audit Log setelah aktivitas	Seluruh aktivitas tercatat dengan detail	✓ Berhasil

4.8.2 Pengujian Keamanan

Tabel 8. Hasil Pengujian Keamanan

No	Jenis Serangan	Hasil	Status WAF
1	SQL Injection (OR 1=1)	HTTP 403 - Diblokir WAF	✓ CRITICAL
2	SQL Injection (DROP TABLE)	HTTP 403 - Diblokir WAF	✓ CRITICAL
3	XSS (<script> tag)	HTTP 403 - Diblokir WAF	✓ HIGH
4	XSS (onerror event)	HTTP 403 - Diblokir WAF	✓ HIGH
5	Path Traversal (../..)	HTTP 403 - Diblokir WAF	✓ CRITICAL
6	Brute Force Login	HTTP 429 - Rate Limited	✓ MEDIUM

4.8.3 Pengujian Performa

Tabel 9. Hasil Pengujian Performa

Endpoint	Rata-rata Waktu Respons	Status
POST /api/auth/login	< 300 ms	✓ Baik
GET /api/students	< 150 ms	✓ Baik
POST /api/certificates/issue	< 500 ms	✓ Baik
POST /api/certificates/:id/approve	< 2000 ms (Blockchain)	✓ Baik
POST	< 200 ms	✓ Baik

/api/certificates/verify		
--------------------------	--	--

BAB V

PENUTUP

5.1 Kesimpulan

Berdasarkan hasil implementasi dan pengujian yang telah dilakukan, dapat disimpulkan bahwa:

- 1 Web Application Firewall (WAF) kustom berhasil diimplementasikan dengan 5 lapisan perlindungan yang efektif dalam mendeteksi dan memblokir serangan SQL Injection (CRITICAL), XSS (HIGH), Path Traversal (CRITICAL), dan Rate Limiting (MEDIUM) dengan tingkat keberhasilan 100% pada seluruh skenario pengujian.
- 2 Zero Trust Architecture berhasil diterapkan melalui Multi-Factor Authentication (MFA) berbasis TOTP yang kompatibel dengan Google Authenticator, serta Role-Based Access Control (RBAC) dengan 6 tingkatan peran yang membatasi akses sesuai prinsip Least Privilege.
- 3 Enkripsi AES-256-CBC berhasil diimplementasikan untuk melindungi data PII (NIK, No. HP, Alamat) siswa, memastikan data sensitif tersimpan dalam bentuk ciphertext yang tidak dapat dibaca tanpa kunci enkripsi yang benar.
- 4 Integrasi Blockchain Ethereum melalui Smart Contract berhasil memberikan jaminan integritas dokumen ijazah yang permanen dan tidak dapat dimanipulasi, dibuktikan dengan keberhasilan deteksi terhadap ijazah yang telah dimodifikasi.
- 5 Portal Verifikasi Publik berhasil dibangun sebagai antarmuka yang memungkinkan pihak eksternal untuk memverifikasi keaslian ijazah secara mudah, transparan, dan tanpa memerlukan akun.
- 6 Seluruh aktivitas pengguna berhasil dicatat dalam Audit Trail yang komprehensif, mendukung keperluan accountability, compliance, dan investigasi insiden keamanan.

5.2 Saran

Berdasarkan penelitian yang telah dilakukan, terdapat beberapa saran untuk pengembangan sistem di masa yang akan datang:

- 1 Deployment ke Cloud: Sistem sebaiknya di-deploy ke lingkungan cloud production (misalnya AWS, Google Cloud, atau Azure) untuk dapat digunakan secara nyata oleh institusi pendidikan.
- 2 Blockchain Publik: Pertimbangkan migrasi dari Hardhat Network lokal ke jaringan Ethereum testnet (Sepolia) atau bahkan mainnet untuk penggunaan produksi yang sesungguhnya.
- 3 Penambahan Fitur: Pengembangan modul presensi digital, sistem pengumuman, dan portal PPDB (Penerimaan Peserta Didik Baru) untuk melengkapi fungsionalitas sistem.
- 4 Aplikasi Mobile: Pengembangan aplikasi mobile Android/iOS yang terintegrasi dengan sistem backend yang sama untuk kemudahan akses.
- 5 Penetration Testing: Melakukan penetration testing secara profesional oleh pihak ketiga yang kompeten untuk mengidentifikasi dan menutup celah keamanan yang mungkin belum terdeteksi.
- 6 Certificate Pinning: Implementasi certificate pinning dan HTTPS untuk memastikan komunikasi antara frontend dan backend terenkripsi sepenuhnya.

DAFTAR PUSTAKA

- Amoroso, E. (2012). "From the Enterprise Perimeter to a Mobility-Enabled Secure Cloud." *IEEE Security & Privacy*, 11(1), 23-31.
- Bertino, E., & Sandhu, R. (2005). "Database Security-Concepts, Approaches, and Challenges." *IEEE Transactions on Dependable and Secure Computing*, 2(1), 2-19.
- Bhargavan, K., & Leurent, G. (2016). "On the Practical (In-)Security of 64-bit Block Ciphers." In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*.
- BSSN. (2023). *Laporan Tahunan Keamanan Siber Indonesia 2023*. Badan Siber dan Sandi Negara Republik Indonesia.
- Buterin, V. (2014). "A Next-Generation Smart Contract and Decentralized Application Platform." *Ethereum White Paper*.
- Chapman, D. B., & Zwicky, E. D. (1995). *Building Internet Firewalls*. O'Reilly Media.
- Daemen, J., & Rijmen, V. (2002). *The Design of Rijndael: AES - The Advanced Encryption Standard*. Springer.
- Ferraiolo, D. F., Sandhu, R., Gavrila, S., Kuhn, D. R., & Chandramouli, R. (2001). "Proposed NIST Standard for Role-Based Access Control." *ACM Transactions on Information and System Security*, 4(3), 224-274.
- Kindervag, J. (2010). "No More Chewy Centers: Introducing The Zero Trust Model Of Information Security." *Forrester Research*.
- M'Raihi, D., Bellare, M., Hoornaert, F., Naccache, D., & Ranen, O. (2005). *HOTP: An HMAC-Based One-Time Password Algorithm*. RFC 4226, Internet Engineering Task Force.
- M'Raihi, D., Machani, S., Pei, M., & Rydell, J. (2011). *TOTP: Time-Based One-Time Password Algorithm*. RFC 6238, Internet Engineering Task Force.
- Nakamoto, S. (2008). "Bitcoin: A Peer-to-Peer Electronic Cash System." *Bitcoin.org*.
- NIST. (2001). *Advanced Encryption Standard (AES)*. Federal Information Processing Standard Publication 197. National Institute of Standards and Technology.

- NIST. (2020). Zero Trust Architecture. Special Publication 800-207. National Institute of Standards and Technology.
- OWASP. (2021). OWASP Top Ten 2021. Open Web Application Security Project. <https://owasp.org/www-project-top-ten/>
- Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). "Role-Based Access Control Models." *IEEE Computer*, 29(2), 38-47.
- Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice* (7th ed.). Pearson Education.
- Swan, M. (2015). *Blockchain: Blueprint for a New Economy*. O'Reilly Media.
- Wood, G. (2014). "Ethereum: A Secure Decentralised Generalised Transaction Ledger." *Ethereum Yellow Paper*.
- Zyskind, G., Nathan, O., & Pentland, A. (2015). "Decentralizing Privacy: Using Blockchain to Protect Personal Data." In *2015 IEEE Security and Privacy Workshops (SPW)*.